

#15

Botnet in a Bottle | Toward A Consolidated Botnet Analysis Pipeline

Zohar Cochavi

Outline

1. Research Question
2. Previously On...
3. This Week's Progress
4. Threat Analysis
5. Continuing Experiments
6. BotConf
7. Next On...
8. Cool Stuff

Research Question

“How can we infer IoT botnet DDoS attack targets, DDoS attack methods, infection targets, and infection methods from sandboxed network traffic alone while restricting allowed communications to the C2 server?”

Subquestions

- ☒ *RQ1*: How can we allow just C2 network traffic while capturing and sinkholing non-C2 traffic to avoid collateral damage?
- ☐ *RQ2*: What traffic features (flow metadata, timing/periodicity, header semantics, inter-flow correlations) best distinguish common IoT DDoS attack types?
- ☐ *RQ3*: How accurate is DDoS attack target and DDoS attack kind extraction?
- ☐ *RQ4*: What features distinguish spreading behavior from DDoS attacking behavior?

Previously On...

First-stage review! Went pretty well, but:

- ☐ Clear need to investigate malware analysis risks
- ☐ Optimizing VMs to use less resources
- ☐ Migrate to shared ClickHouse database
- ☐ Store PCAPs in ClickHouse

And from now on:

- ☐ Keep writing

This Week's Progress

First-stage review! Went pretty well, but:

- ☒ Clear need to investigate malware analysis risks
- ☐ Optimize VMs to use less resources
- ☒ Migrate to shared ClickHouse database
- ☐ Store PCAPs in ClickHouse

And from now on:

- ☒ Keep writing

Threat Analysis

Long story short:

- QEMU doesn't give security guarantees
- We should minimize impact first, then harden sandbox

With that,

- No access to intranet, save *rhodos* on port *9000*.
- Separate ClickHouse credentials with minimal insert-only permissions
- SSH access through separate VPN with minimal ACL permissions
- Active monitoring with an EDR

May be Overkill

Did a bit of reporting on this, so let me know if you'd like to read it!

Bottle Threat Analysis

Zohar Cochavi

But not Complete

There are some things which might be interesting to add:

- We don't cover the NFTables configuration
- Possible impact on Proxmox (effectively the same, just another layer)
- Routing configuration on Proxmox
- Routing of traffic beyond Proxmox (e.g. Thunderlab setup)

I'll probably include this in the thesis as a separate chapter?

Continuing Experiments

A couple of considerations:

- We can continue this way, and increase scale later
- But first, we should implement the recommendations
- Ensure the necessary information is centralized (bottle ledger?)

Profit?

- I also need to do something with n8n, but I'm not sure where to put it...

BotConf

The deadline is in two weeks:

- A short talk is okay?
- Should I include results in the proposal? (if so what?)

I think it would be super cool to participate!

Next On...

Ensure we can run the experiments:

- ☐ Implement recommendations
- ☐ Ensure PCAP data is stored in ClickHouse

Maybe:

- ☐ Write ledger events to ClickHouse?

As for writing:

- ☐ I'll start on *How Botnets Work*

Cool Stuff

This is pretty interesting:

- <https://polygonben.github.io/malware%20analysis/Compromising-Threat-Actor-Communications/#case-study>
- <https://www.virustotal.com/gui/file/9ef489493d3fffa0d8e43b6a189d471430ba0fdc33def06d0e43d809413d5837/detection>